

Ethical Hacking

Notes collected during lessons. Not corrected.

Riccsrdo

Master Degree in Cybersecurity



IMPORTANT DISCLAIMER: These notes have been taken during lessons. They might contain errors (specifically, grammatical errors) and be incorrect. Please always check other sources to confirm what is written is correct. I don't think I'll correct them after lessons, though it's possible.

February 25, 2026

Contents

1	Introduction	2
1.1	Course Introduction	2
2	Theory: Part 1	3
2.1	Footprinting	4
3	Practical Part: Part 1	7

Chapter 1

Introduction

1.1 Course Introduction

For the recommended textbook, we are following
Hacking Exposed 7: Network Security Secrets & Solutions.

24/02/2026

The major topics we'll cover are:

- Footprinting
- Scanning
- Enumeration
- Advanced Persistent Threat
- Hacking:
 - Web Hacking
 - Unix Hacking
 - Wireless Hacking
 - Hardware Hacking
 - Mobile Hacking

It's recommended to train with HackTheBox website. If you get +45 points on the website, you are awarded +1 at the final grade. Another website that is recommended is given by Try to Hack (or something like this).

We'll have a Lab project. It's optional, and it will account for 49% of the final grade. The rest of the grade will be given by a written exam. If we want to skip the lab project, then 100% of the final grade will be given by the final exam. The written exam is given by 5 questions.

Chapter 2

Theory: Part 1

We'll start with taking a look at **Footprinting, Scanning and Enumeration**.

Attackers, before performing an attack, will perform some kind of investigation to determine the vulnerabilities they can use at their own advantage. We are considering professional hackers, who don't want to be detected when they're entering the system.

Attackers behave as insiders when breaking a system, even if he could be outside the company. When we perform Ethical Hacking, we need to be inside the company, having the same vision an hacker has.

Also, the major concern of an hacker is to be anonymous, as well as being stealthy. At the basic of anonymity there is **Tor Project**. As the graphical user interface for Tor, Vidalia is used, while for web filtering proxy we have Privoxy. To solve IP addresses, it's possible to do this Tor as well, with **tor-resolve**. For proxychains, **Nmap** is well known. It's a tool that allows to do some sophisticated protocols. Once another tool is given by **nc** (netcat), used to send requests to servers.

Onion Router (TOR)

We have the usual scheme, with Alice wanting to talk with Bob. However, they want the possibility to deny they're communicating, leaving no trace of their communication. The protocol works with three layers of routers, located around the world, and there are hundreds of thousand of them. Alice will pick three random routers. These routers will have special names: **guard node**, the node to which Alice is talking (entry point of the network); **exit-node**. This is called Onion Router because the packet that is used is composed by many envelops. The main message is covered in many other messages. We have both encrypted and unencrypted links. Encryption is implemented by Tor protocol, but on top of this we can have more encryption on top of it. Tor protocol is also transparent to the communication. The packet being sent is encrypted three times, with three different keys, one after the other. The key is given by the Tor node that Alice has selected. Each node has a public and a private key. The guard node is the most external envelope of the encryption. The guard node then decrypts the outside of the message, forwarding it to the second node.

So the sender prepares these onion messages, with every node removing one layer, and passing it to the next of the three nodes (randomly picked nodes).
Correct this part, I got a bit lost.

2.1 Footprinting

So far, we've seen tools to find information about the target we attack. Before that, however, Footprinting is performed. It works without even sending to the target a single packet. So, we need to find information about the organization without even interacting. Footprinting should be executed also by us Ethical Hackers. This is internet Footprinting:

1. Determine the scope of your activities: we need to understand what I actually need to do, avoiding to inadvertently committing crimes.
2. Get proper authorization: the scope should be linked with our authorization to the system. The contract will tell us what we can and what we cannot do.
3. Check publicly available information
4. WHOIS & DNS enumeration
5. DNS interrogation
6. Network Reconnaissance.

Why is footprinting important? Hackers need to collect information about the target, without this phase they will not be able to execute the attack. Thus, profiling of an organization. What can we get about the target organization publicly?

25-02-2026

- Internet: domain names, network blocks, IP addresses, TCP/UDP services;
- Intranet: network protocols, internal domain names, services, access control;
- Remote access: remote system type, auth. mechanisms, VPN;
- Extranet: large organizations usually have partners, so their network can be connected to partner's network, and hackers could get into the network through the partner.

Let's start with internet footprinting. First of all, as a defender we need to choose the scope of our activity, we have to agree with the management what do we have to do, like profiling the entire organization or only a part. For the full organization, it may be worth but also very time consuming, as it might need a lot of employees. The relation between us and the management needs to be clear. All activities related to penetration testing and ethical hacking needs to be accepted by the management.

So, the second step is getting proper authorization. A proper funding is necessary to do this step.

Let's now see the company web pages. They have public pages, what is shown, and private, they're not shown but they're still there. By looking at web pages, it's possible to identify security configurations, asset inventory, and other documents. We can also find the HTML source code, it gives information specifically in comments, which could contain important elements like passwords. As a defender, we can query the web pages as much as we want, while as attackers we'll have to use some mirroring tools, like `wget`, doing then an analysis offline, on a local copy. Also, there are hidden files, and we can use tools like `OWASP`. After all these steps, we need to repeat this process for all websites of the company, like `www1`, `www2`, `web`, `test`, as well as VPN sites. After we've done this, we need to consider related organizations. Attacks like social engineering could be portraided.

Next step is collecting employees information. Information like their names, email addresses, phone numbers, other personal details (like home addresses), social network details, etc.

Alongside this, we can take a look at job postings and resumes. Also, at how the company is doing, like the economical state of it. Look for merges, acquisitions, scandals, outsourcing. For example, if we deal with merge and acquisition, there needs to be a merge of two IT systems, which could be problematic and messy. As a consequence, security decreases. In addition to this, we have the human factor, with a lot of work to do, low morale, etc.

We can also take a look at archived information about the organization, cached and maintained in other websites. Services like `archive.org` does the work for us.

What is the counter measure for all of this? We need to periodically review and remove public sensitive data, as much as possible.

Once another source is given by WHOIS and DNS enumeration. Internet is completely distributed, there are independent routers everywhere. However, the management is centralized. The ICANN organization deals with the management part, assigning and guaranteeing correspondences between names and physical addresses. This database of logical names and IPs is also distributed, and is handled by two services, WHOIS and `??`. By querying these services, we can get a lot of information about the organization, like IP addresses, name, mail services domains, etc.

Also the information contained in DNS servers could be quite useful. DNS could be queried (but it could be slow), or perform DNS zone transfer. This operation is useful to transfer information to increase reliability. However, when this takes place all the information is transferred between one machine to one another, and any attacker can do that. A specific tool is given by `dnsrecon`. Another command is given by `nslookup`.

What are the countermeasures? We can restrict transfers only to authorized servers, use a firewall, denying all unauthorized connections to port TCP 53, and also not to put relevant information on HINFO records.

After we've collected all this data, we can perform network reconnaissance. It allows a hacker to identify network topology, and requires the sending of packets. Tools like `traceroute` can be used. The countermeasures are given by

intrusion detection systems, blocking ICMP packets and UDP traffic.

Do the homework!

Chapter 3

Practical Part: Part 1